inquiry@cyart.io

www.cyart.io

TASK: - Vulnerability Assessment and Penetration Testing

Weekly Work Report

Submitted by: Rupapara Khush

Date: February 06, 2026

Domain: VAPT(Intern)

Executive Summary

Reporting Period	February Weak 1, 2026
Primary Focus	Theoretical Foundations & Practical VAPT
Target Systems	Metasploitable 3 (192.168.1.5), OWASP Juice Shop (127.0.0.1:3000)
Tools Used	Nmap, OpenVAS, Nikto, Docker
Critical Findings	3 Critical, 4 High, 13 Medium vulnerabilities
Status	In Progress - Learning Phase

Table of Contents

1. Theoretical Knowledge Learning
2. Practical Application & Testing
3. Vulnerability Assessment Results
4. Key Findings & Analysis
5. Lessons Learned & Next Steps

1. Theoretical Knowledge Learning

During the first two days, I focused on building a strong theoretical foundation in vulnerability assessment and penetration testing methodologies.

1.1 Understanding Security Assessment

Objective: Learn how to evaluate systems without paid tools.

Key Concepts Learned:

- Security Assessment Framework: Identification of weaknesses using NIST guidelines and industry-standard frameworks
- Types of Security Testing:
  - Vulnerability Assessment using OpenVAS (open-source vulnerability scanner)
  - Penetration Testing with Kali Linux tools (Metasploit, Nmap)
  - Compliance Testing using CIS Benchmarks and security checklists

1.2 VAPT Methodology

Objective: Follow a structured approach using industry-standard methodologies.

Methodology Phases:

Phase	Activities	Tools Used
Planning	Define scope and objectives	Dradis CE
Discovery	Network and service enumeration	Nmap, OWASP ZAP
Attack	Exploit identified vulnerabilities	Metasploit Framework
Reporting	Document findings and remediation	Custom templates

Framework Reference: Practiced the OWASP Web Security Testing Framework for comprehensive web application testing.

1.3 Security Standards & Compliance

Objective: Align security assessments with industry regulations and standards.

- Standards Studied: GDPR, HIPAA, ISO 27001
- Primary Reference: Used OWASP Top 10 to prioritize web application vulnerabilities
- Risk Prioritization: Learned to categorize vulnerabilities based on industry standards

1.4 Risk Assessment Basics

Objective: Prioritize vulnerabilities using standardized scoring systems.

- CVSS Calculator: Utilized the NVD CVSS Calculator for vulnerability scoring
- Risk Matrix: Categorized risks as High/Medium/Low using structured assessment criteria
- Documentation: Used spreadsheets (Google Sheets/Excel) for tracking and analysis

1.5 Common Vulnerabilities

Vulnerability Categories Studied:

Category	Examples	Testing Environment
Network Vulnerabilities	Misconfigurations, open ports	Nmap on Metasploitable
Web Vulnerabilities	SQL Injection, XSS	OWASP Juice Shop
Authentication Flaws	Weak credentials, brute force	VulnHub machines

Service Vulnerabilities	Outdated software, default configs	Metasploitable 3

Learning Labs:

- Metasploitable 3 - Intentionally vulnerable VM for practice
- OWASP Juice Shop - Modern web application security training
- VulnHub - Community-driven vulnerable machines

1.6 Documentation Fundamentals

Tools and Templates:

- Dradis CE - Collaborative reporting platform
- CherryTree - Technical note-taking for findings
- GitHub Templates - Professional report templates

2. Practical Application & Testing

After building theoretical knowledge, I transitioned to hands-on practice with real vulnerable applications and systems.

2.1 Testing Environment Setup

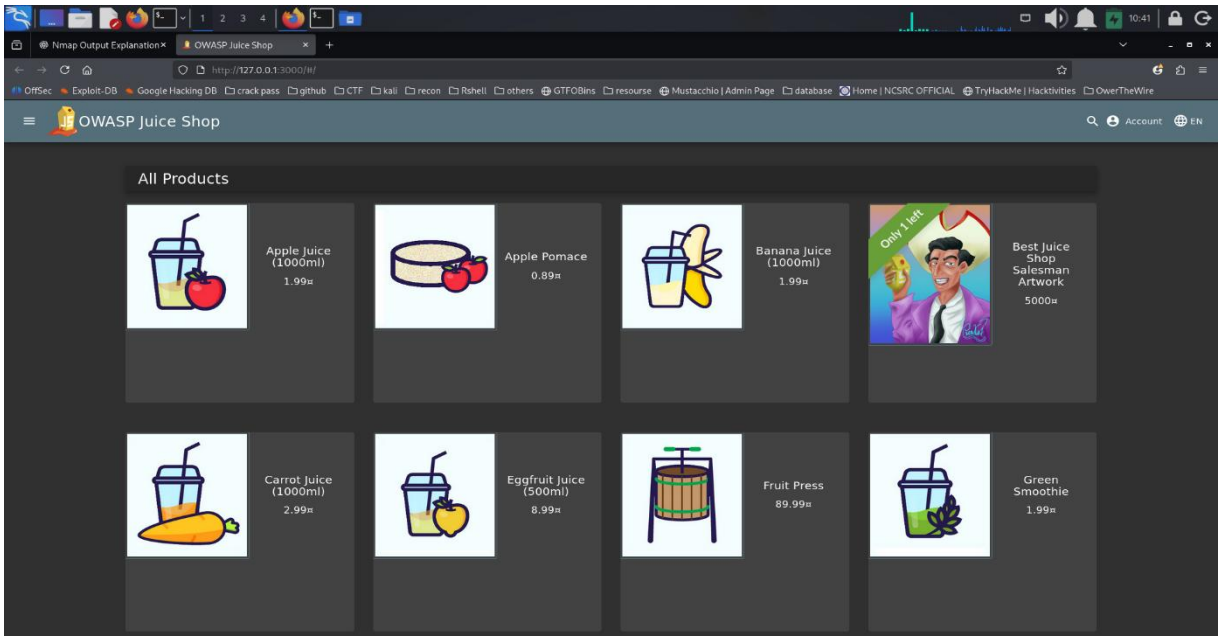
Environment Configuration:

Component	Details
Host OS	Kali Linux (primary testing platform)
Virtualization	VirtualBox for isolated testing environments
Target 1	OWASP Juice Shop (127.0.0.1:3000) - Containerized
Target 2	Metasploitable 3 (192.168.1.5) - Virtual Machine
Container Platform	Docker for application deployment
Network Configuration	eth0: 192.168.1.5, eth1: 172.28.128.3

2.2 OWASP Juice Shop - Web Application Testing

Deployment:

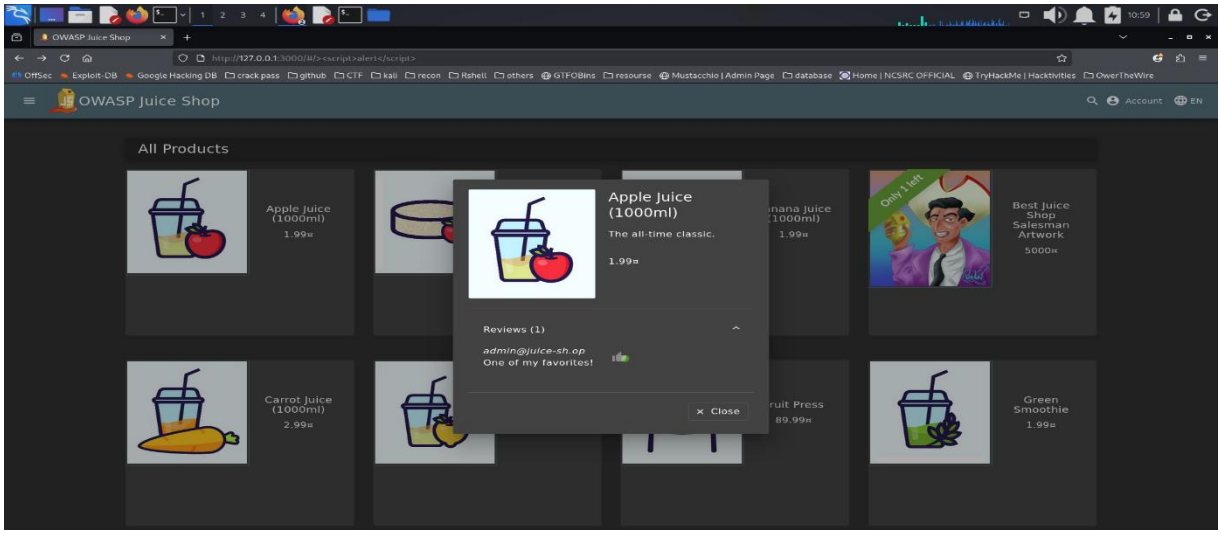
- Started Docker service using 'sudo systemctl start docker'
- Deployed OWASP Juice Shop container on port 3000
- Command: 'sudo docker run -d -p 3000:3000 bkimminich/juice-shop'

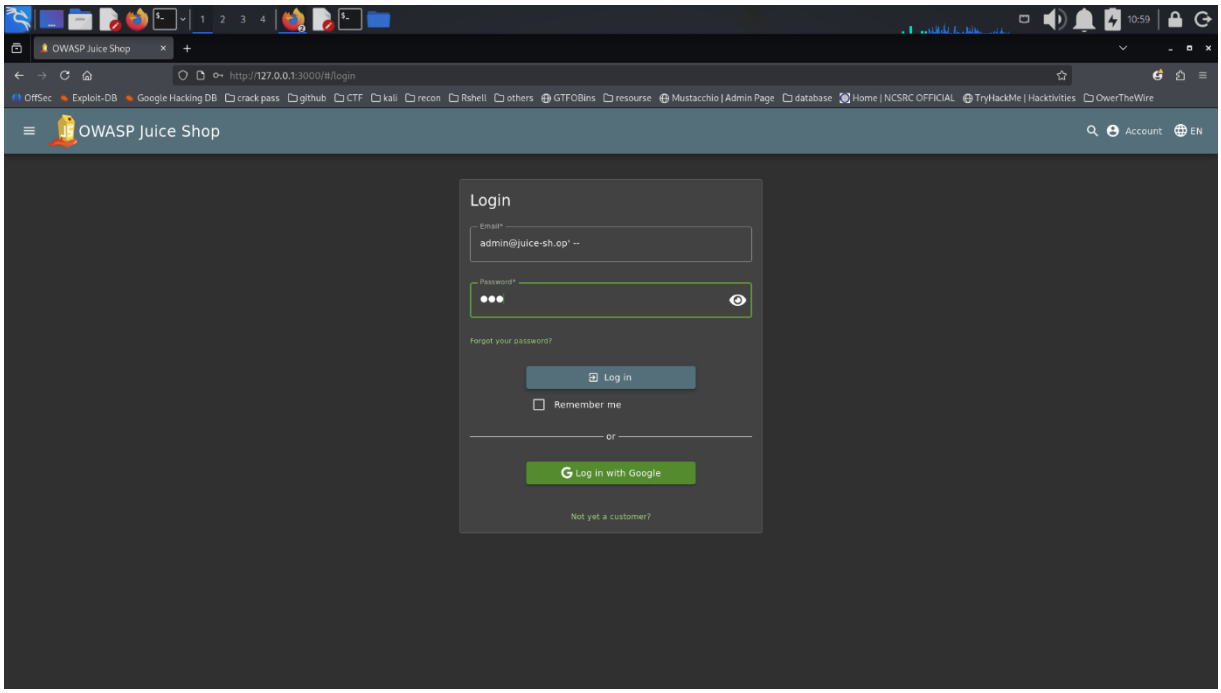


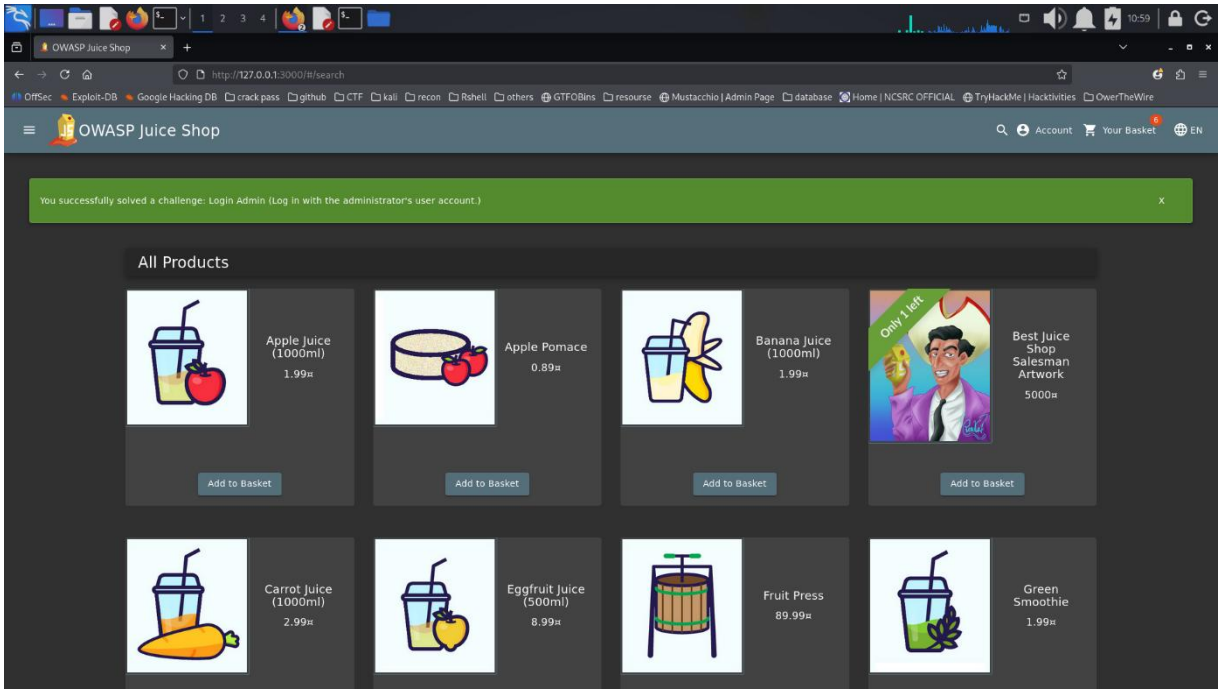
Vulnerabilities Discovered & Exploited:

2.2.1 SQL Injection (SQLi)

- **Vulnerability Type:** Authentication Bypass via SQL Injection
- **Location:** Login form (email field)
- **Exploit Method:** Injected SQL payload in email field to bypass authentication
- **Impact:** Successfully logged in as administrator without valid credentials
- **Evidence:** Challenge solved notification: 'Login Admin (Log in with the administrator's user account)'



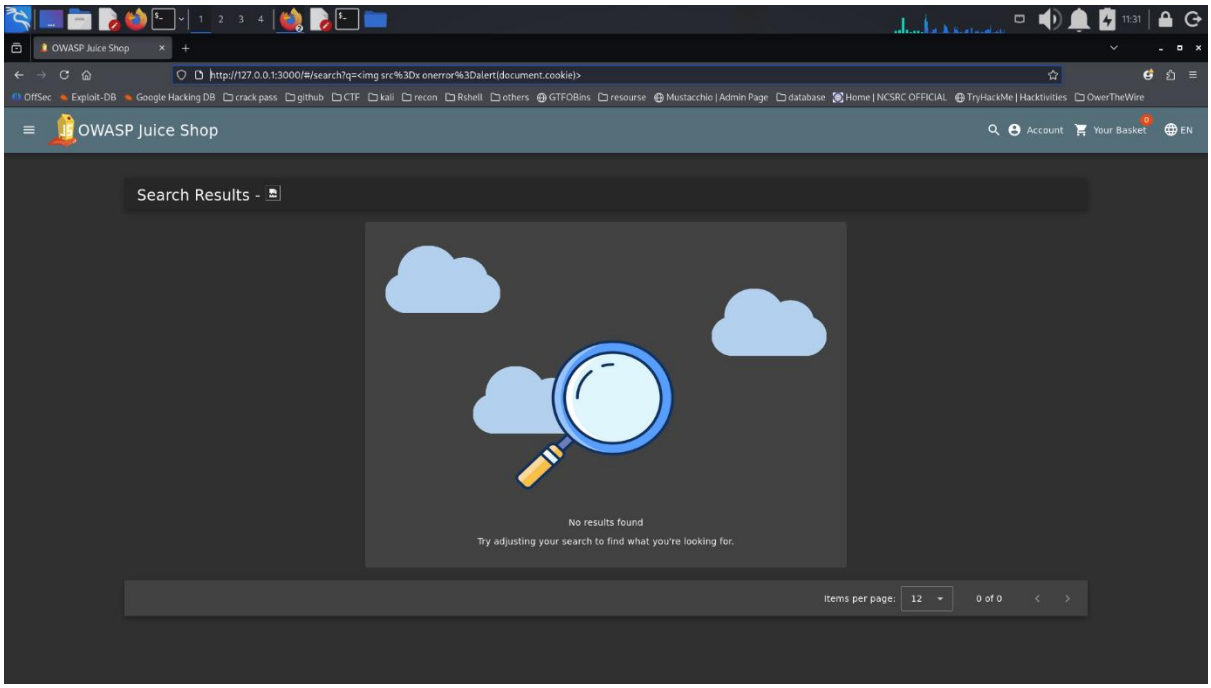


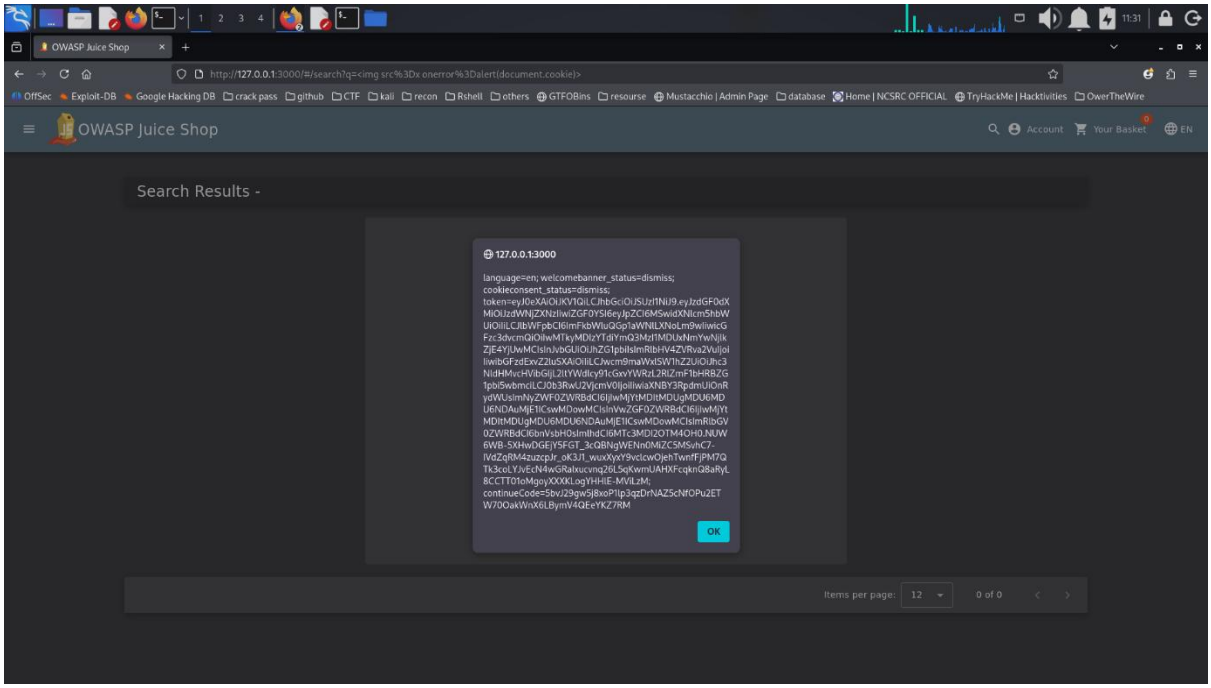


2.2.2 Cross-Site Scripting (XSS)

- **Vulnerability Type:** Stored XSS and DOM-based XSS
- **Location:** Search functionality and product reviews
- **Exploit Method:** Injected JavaScript payload into search and review fields

- **Impact:** JavaScript code executed in browser context
- **Evidence:** XSS payload triggered alert dialogs in application





2.2.3 Other Security Challenges Completed

- **Error Handling:** Provoked error that is neither gracefully nor consistently handled
- **Security Policy:** Behaved like a white-hat hacker by reviewing security.txt

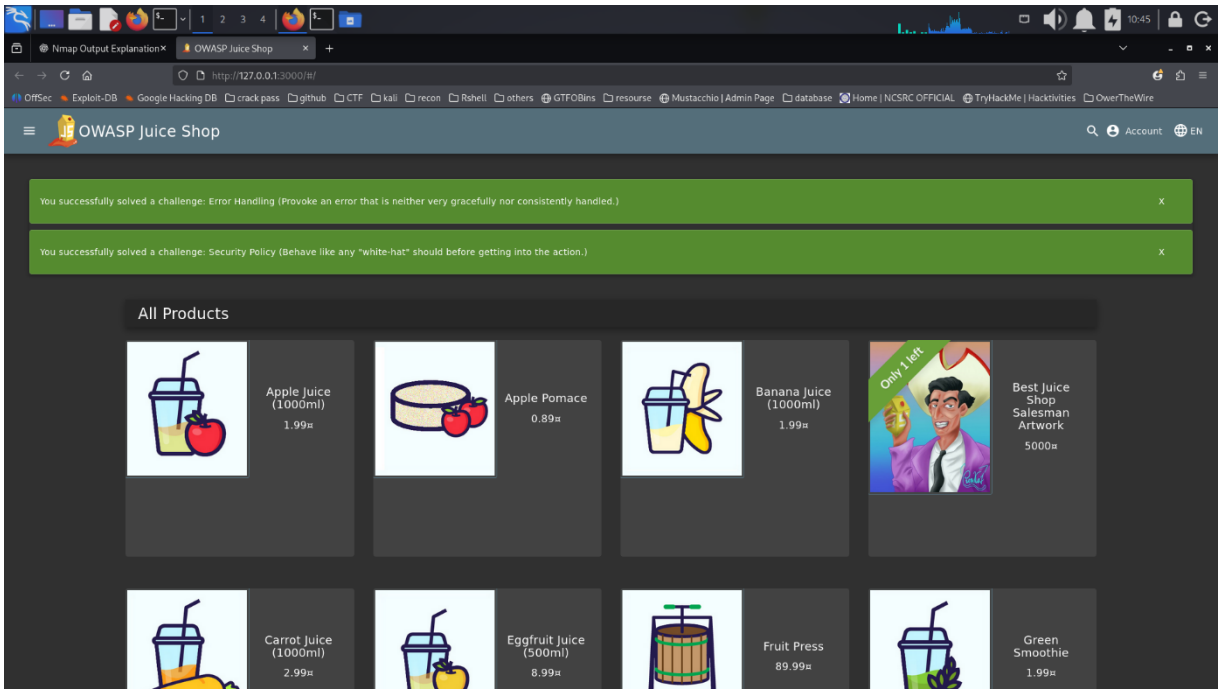
```
┌──(bobby㉿bobby)-[~/Desktop/Internship]
└─$ nikto -h http://127.0.0.1:3000 -o nikto_report.txt

- Nikto v2.5.0
---------------------------------------------------------------------------
+ Target IP:          127.0.0.1
+ Target Hostname:    127.0.0.1
+ Target Port:        3000
+ Start Time:         2026-02-05 10:46:04 (GMT5.5)
---------------------------------------------------------------------------
+ Server: No banner retrieved
+ /: Retrieved access-control-allow-origin header: *.
+ /: Uncommon header 'x-recruiting' found, with contents: /#/jobs.
+ No CGI Directories found (use '-C all' to force check all possible dirs)
+ /robots.txt: Entry '/ftp/' is returned a non-forbidden or redirect HTTP code (200). See: https://portswigger.net/kb/issues/00600600_robots-txt-file
+ /robots.txt: contains 1 entry which should be manually viewed. See: https://developer.mozilla.org/en-US/docs/Glossary/Robots.txt
+ /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type.
 See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/
+ /database.egg: Potentially interesting backup/cert file found. . See: https://cwe.mitre.org/data/definitions/530.html
+ /127001.war: Potentially interesting backup/cert file found. . See: https://cwe.mitre.org/data/definitions/530.html
+ /12700.jks: Potentially interesting backup/cert file found. . See: https://cwe.mitre.org/data/definitions/530.html
+ /127_0_0_1.tgz: Potentially interesting backup/cert file found. . See: https://cwe.mitre.org/data/definitions/530.html
+ /backup.tgz: Potentially interesting backup/cert file found. . See: https://cwe.mitre.org/data/definitions/530.html
+ /site.egg: Potentially interesting backup/cert file found. . See: https://cwe.mitre.org/data/definitions/530.html
+ /127_0_0_1.tar.lzma: Potentially interesting backup/cert file found. . See: https://cwe.mitre.org/data/definitions/530.html
+ /backup.tar.lzma: Potentially interesting backup/cert file found. . See: https://cwe.mitre.org/data/definitions/530.html
+ /12700.alz: Potentially interesting backup/cert file found. . See: https://cwe.mitre.org/data/definitions/530.html
+ /dump.jks: Potentially interesting backup/cert file found. . See: https://cwe.mitre.org/data/definitions/530.html
+ /127_0_0_1.jks: Potentially interesting backup/cert file found. . See: https://cwe.mitre.org/data/definitions/530.html
+ /dump.war: Potentially interesting backup/cert file found. . See: https://cwe.mitre.org/data/definitions/530.html
+ /1.alz: Potentially interesting backup/cert file found. . See: https://cwe.mitre.org/data/definitions/530.html
+ /127001.jks: Potentially interesting backup/cert file found. . See: https://cwe.mitre.org/data/definitions/530.html
+ /127001.tar.bz2: Potentially interesting backup/cert file found. . See: https://cwe.mitre.org/data/definitions/530.html
+ /dump.tar: Potentially interesting backup/cert file found. . See: https://cwe.mitre.org/data/definitions/530.html
+ /1.war: Potentially interesting backup/cert file found. . See: https://cwe.mitre.org/data/definitions/530.html
+ /12700.egg: Potentially interesting backup/cert file found. . See: https://cwe.mitre.org/data/definitions/530.html
+ /dump.tgz: Potentially interesting backup/cert file found. . See: https://cwe.mitre.org/data/definitions/530.html
+ /dump.tar.bz2: Potentially interesting backup/cert file found. . See: https://cwe.mitre.org/data/definitions/530.html
+ /12700.tgz: Potentially interesting backup/cert file found. . See: https://cwe.mitre.org/data/definitions/530.html
```

```
┌──(bobby㉿bobby)-[~/Desktop/Internship]
└─$ nmap -p 80,443,3000 -sV 127.0.0.1

Starting Nmap 7.98 ( https://nmap.org ) at 2026-02-05 10:44 +0530
Nmap scan report for localhost (127.0.0.1)
Host is up (0.00026s latency).

PORT     STATE  SERVICE VERSION
80/tcp   closed http
443/tcp  closed https
3000/tcp open   ppp?
1 service unrecognized despite returning data. If you know the service/version, please submit the following fingerprint at https://nmap.org/cgi-bin/submit.cg
i?new-service :
SF-Port3000-TCP:V=7.98%I=7%D=2/5%Time=6984273F%P=x86_64-pc-linux-gnu%r(Get
SF:Request,101B9,"HTTP/1\.1\x20200\x20OK\r\nAccess-Control-Allow-Origin:\x
SF:20\*\r\nX-Content-Type-Options:\x20nosniff\r\nX-Frame-Options:\x20SAMEO
SF:RIGIN\r\nFeature-Policy:\x20payment\x20'self'\r\nX-Recruiting:\x20/#/jo
SF:bs\r\nAccept-Ranges:\x20bytes\r\nCache-Control:\x20public,\x20max-age=0
SF:\r\nLast-Modified:\x20Thu,\x2005\x20Feb\x202026\x2005:05:45\x20GMT\r\nE
SF:Tag:\x20W/\"1252f-19c2c312a98\"\r\nContent-Type:\x20text/html;\x20chars
SF:et=UTF-8\r\nContent-Length:\x2075055\r\nVary:\x20Accept-Encoding\r\nDat
SF:e:\x20Thu,\x2005\x20Feb\x202026\x2005:14:39\x20GMT\r\nConnection:\x20cl
SF:ose\r\n\r\n<!—— \n\x20\x20~\x20Copyright\x20\(c\)\x202014-2026\x20Bjoern
SF:\x20Kimminich\x206\x20the\x20OWASP\x20Juice\x20Shop\x20contributors\.\n
SF:\x20\x20~\x20SPDX-License-Identifier:\x20MIT\n\x20\x20——>\n\n<!doctype\
SF:x20html>\n<html\x20lang=\"en\"\x20data-beasties-container>\n<head>\n\x2
SF:0\x20<meta\x20charset=\"utf-8\">\n\x20\x20<title>OWASP\x20Juice\x20Shop
SF:</title>\n\x20\x20<meta\x20name=\"description\"\x20content=\"Probably\x
SF:20the\x20most\x20modern\x20and\x20sophisticated\x20insecure\x20web\x20a
SF:pplication\">\n\x20\x20<meta\x20name=\"viewport\"\x20content=\"width=de
SF:vice-width,\x20initial-scale=1\">\n\x20\x20<link\x20id=\"favicon\"\x20r
SF:el=\"icon\"\x20")%r(Help,2F,"HTTP/1\.1\x20400\x20Bad\x20Request\r\nConn
SF:ection:\x20close\r\n\r\n")%r(NCP,2F,"HTTP/1\.1\x20400\x20Bad\x20Request
SF:\r\nConnection:\x20close\r\n\r\n")%r(HTTPOptions,EA,"HTTP/1\.1\x20204\x
SF:20No\x20Content\r\nAccess-Control-Allow-Origin:\x20\*\r\nAccess-Control
SF:-Allow-Methods:\x20GET,HEAD,PUT,PATCH,POST,DELETE\r\nVary:\x20Access-Co
SF:ntrol-Request-Headers\r\nContent-Length:\x200\r\nDate:\x20Thu,\x2005\x2
SF:0Feb\x202026\x2005:14:39\x20GMT\r\nConnection:\x20close\r\n\r\n")%r(RTS
SF:PRequest,EA,"HTTP/1\.1\x20204\x20No\x20Content\r\nAccess-Control-Allow-
SF:Origin:\x20\*\r\nAccess-Control-Allow-Methods:\x20GET,HEAD,PUT,PATCH,PO
```



Learning Outcomes:

- Understood practical exploitation techniques for common web vulnerabilities
- Learned how improper input validation leads to security breaches
- Practiced ethical hacking within controlled environments

2.3 Metasploitable 3 - Network Vulnerability Assessment

```
          RX bytes:0 (0.0 B)  TX bytes:2627 (2.6 KB)

eth0      Link encap:Ethernet  HWaddr 08:00:27:79:fe:90
          inet addr:192.168.1.5  Bcast:192.168.1.255  Mask:255.255.255.0
          inet6 addr: fe80::a00:27ff:fe79:fe90/64 Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:4507 errors:0 dropped:0 overruns:0 frame:0
          TX packets:643 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:6635328 (6.6 MB)  TX bytes:53881 (53.8 KB)

eth1      Link encap:Ethernet  HWaddr 08:00:27:29:8a:1b
          inet addr:172.28.128.3  Bcast:172.28.128.255  Mask:255.255.255.0
          inet6 addr: fe80::a00:27ff:fe29:8a1b/64 Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:1 errors:0 dropped:0 overruns:0 frame:0
          TX packets:89 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:60 (60.0 B)  TX bytes:13036 (13.0 KB)

lo        Link encap:Local Loopback
          inet addr:127.0.0.1  Mask:255.0.0.0
          inet6 addr: ::1/128 Scope:Host
          UP LOOPBACK RUNNING  MTU:65536  Metric:1
          RX packets:890 errors:0 dropped:0 overruns:0 frame:0
          TX packets:890 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:0
          RX bytes:198419 (198.4 KB)  TX bytes:198419 (198.4 KB)

vagrant@metasploitable3-ub1404:~$ _
```

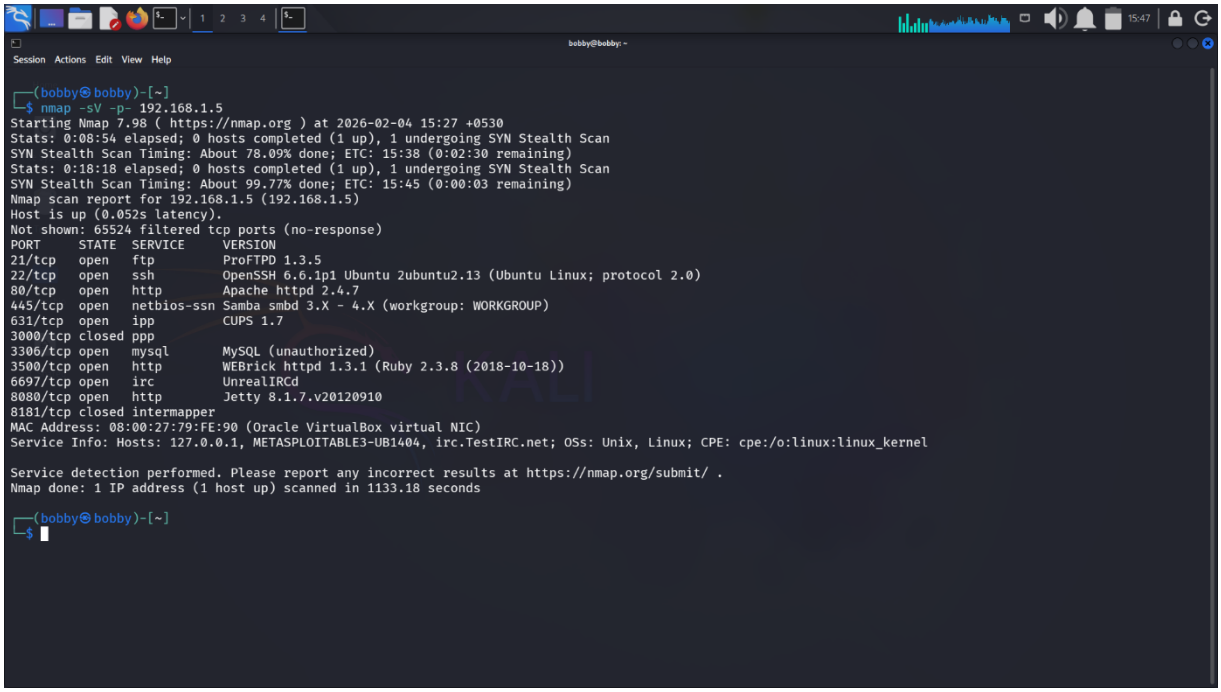
Target System:

Parameter	Value
IP Address	192.168.1.5
Operating System	METASPLOITABLE3-UB1404 (Ubuntu Linux)
MAC Address	08:00:27:79:FE:90 (Oracle VirtualBox NIC)
Network Interface	eth0: 192.168.1.5/24

2.3.1 Network Scanning with Nmap

Scan Commands Executed:

- **Basic Service Version Scan:** nmap -sV 192.168.1.5
- **Comprehensive Port Scan:** nmap -sV -p- 192.168.1.5



```
┌──(bobby㉿bobby)-[~]
└─$ nmap -sV -p- 192.168.1.5
Starting Nmap 7.98 ( https://nmap.org ) at 2026-02-04 15:27 +0530
Stats: 0:08:54 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 78.09% done; ETC: 15:38 (0:02:30 remaining)
Stats: 0:18:18 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 99.77% done; ETC: 15:45 (0:00:03 remaining)
Nmap scan report for 192.168.1.5 (192.168.1.5)
Host is up (0.052s latency).
Not shown: 65524 filtered tcp ports (no-response)
PORT     STATE  SERVICE     VERSION
21/tcp   open   ftp         ProFTPD 1.3.5
22/tcp   open   ssh         OpenSSH 6.6.1p1 Ubuntu 2ubuntu2.13 (Ubuntu Linux; protocol 2.0)
80/tcp   open   http        Apache httpd 2.4.7
445/tcp  open   netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
631/tcp  open   ipp         CUPS 1.7
3000/tcp closed ppp
3306/tcp open   mysql       MySQL (unauthorized)
3500/tcp open   http        WEBrick httpd 1.3.1 (Ruby 2.3.8 (2018-10-18))
6697/tcp open   irc         UnrealIRCd
8080/tcp open   http        Jetty 8.1.7.v20120910
8181/tcp closed intermapper
MAC Address: 08:00:27:79:FE:90 (Oracle VirtualBox virtual NIC)
Service Info: Hosts: 127.0.0.1, METASPLOITABLE3-UB1404, irc.TestIRC.net; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 1133.18 seconds

┌──(bobby㉿bobby)-[~]
└─$
```

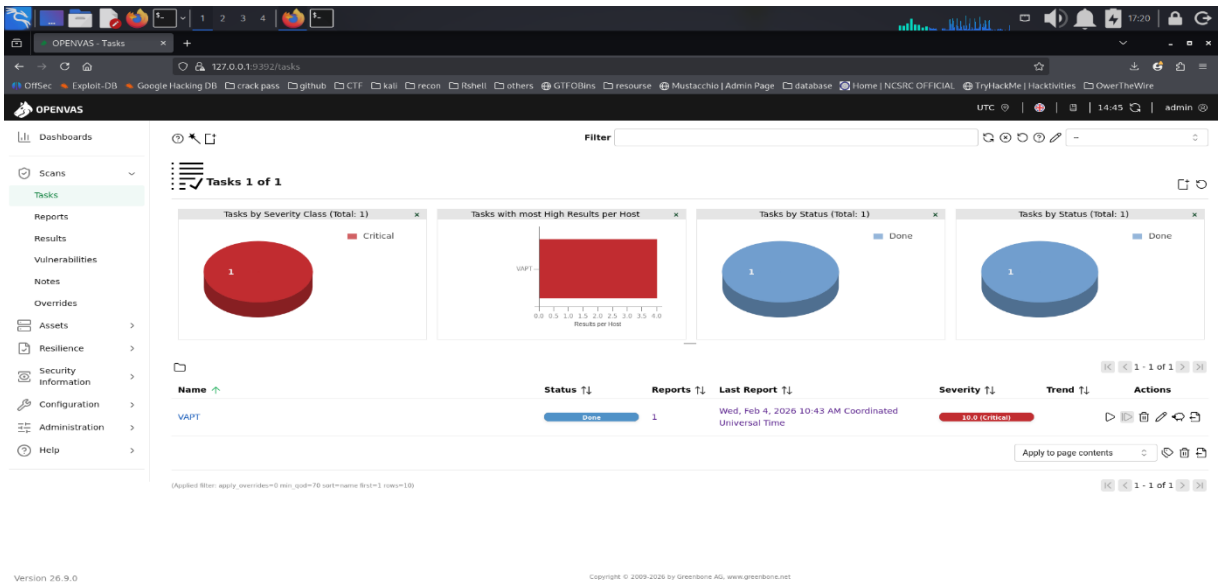
Open Ports and Services Discovered:

Port	State	Service	Version
21/tcp	open	ftp	ProFTPD 1.3.5
22/tcp	open	ssh	OpenSSH 6.6.1p1 Ubuntu
80/tcp	open	http	Apache httpd 2.4.7
445/tcp	open	netbios-ssn	Samba smbd 3.X - 4.X
631/tcp	open	ipp	CUPS 1.7
3000/tcp	closed	ppp	-
3306/tcp	open	mysql	MySQL (unauthorized)
3500/tcp	open	http	WEBrick httpd 1.3.1 (Ruby)
6697/tcp	open	irc	UnrealIRCd
8080/tcp	open	http	Jetty 8.1.7.v20120910
8181/tcp	closed	intermapper	-

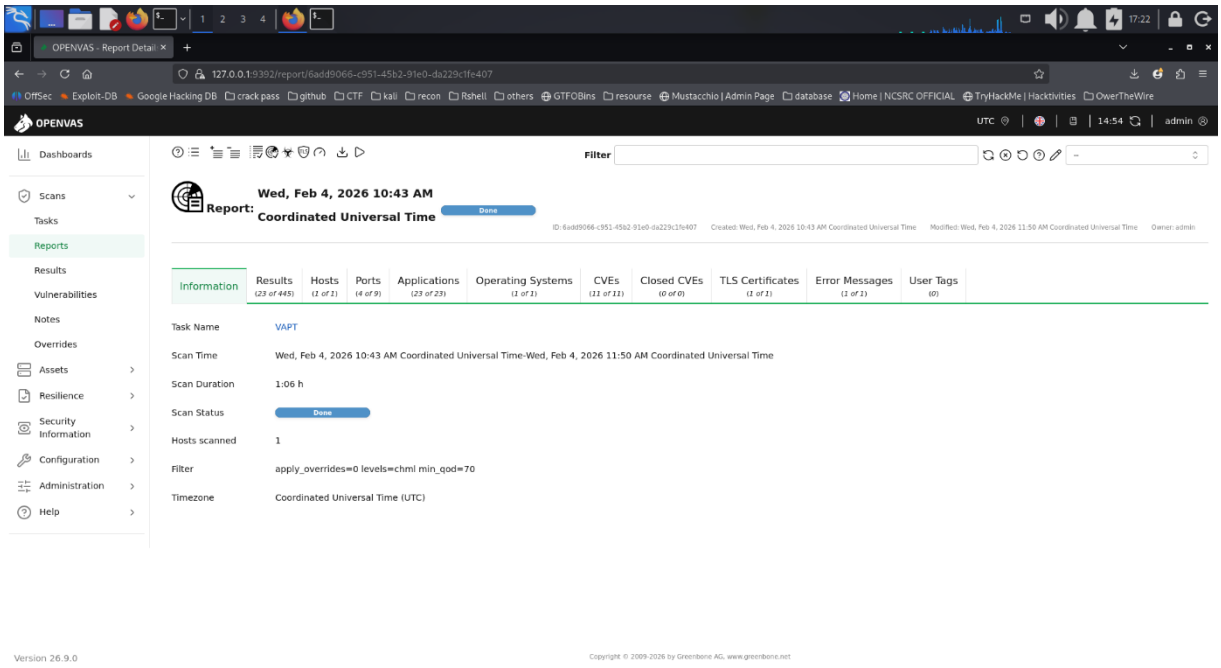
3. Vulnerability Assessment Results

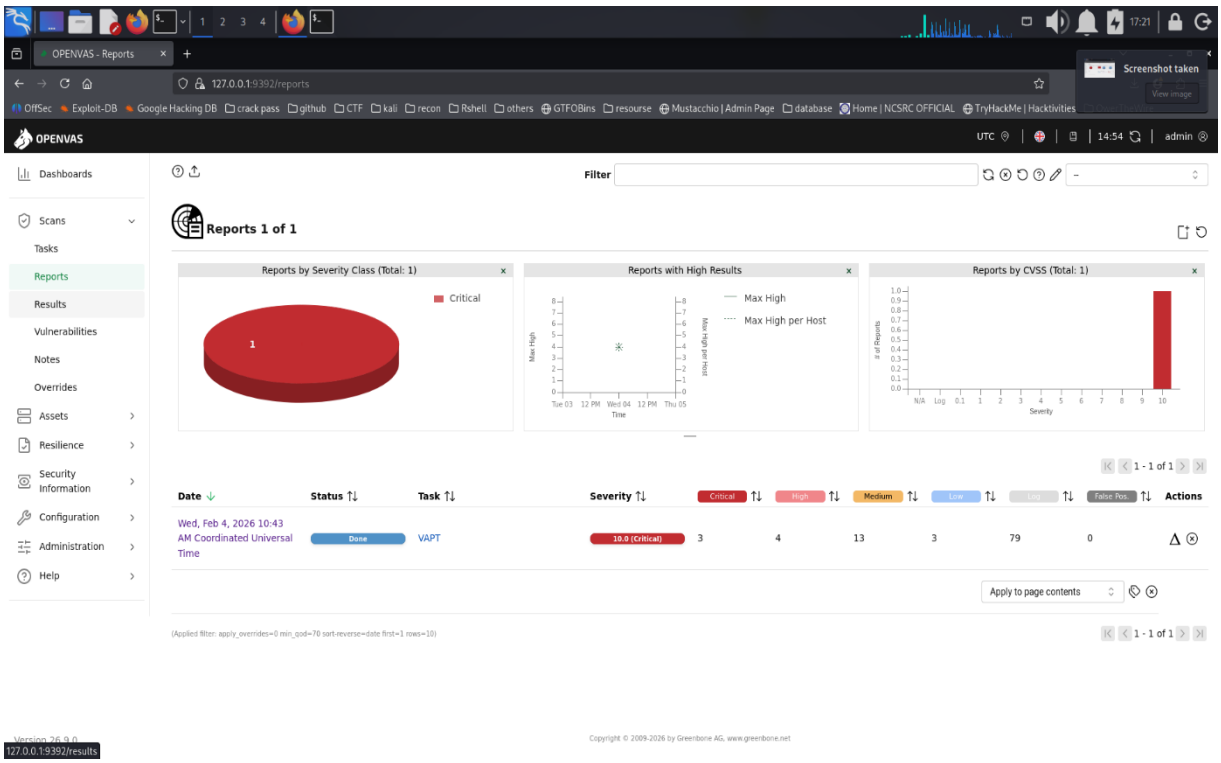
Comprehensive vulnerability assessment was performed using OpenVAS on target system 192.168.1.5.

3.1 OpenVAS Scan Overview



Parameter	Details
Scan Task Name	VAPT
Target	192.168.1.5 (Metasploitable 3)
Scan Duration	1 hour 6 minutes
Scan Date	Wednesday, February 4, 2026 10:43 AM UTC
Scan Status	Done
Hosts Scanned	1
Total Vulnerabilities	102 of 445
Filter Applied	apply_overrides=0 levels=chml min_qod=70


OPENVAS - Report Detail
127.0.0.1:9392/report/6add9066-c951-45b2-91e0-da229c1fe407
OPENVAS
Dashboards
Scans
Tasks
Reports
Results
Vulnerabilities
Notes
Overrides
Assets
Resilience
Security Information
Configuration
Administration
Help
Filter
Report: Wed, Feb 4, 2026 10:43 AM Coordinated Universal Time
Done
Information
Results (23 of 445)
Hosts (2 of 1)
Ports (4 of 9)
Applications (23 of 23)
Operating Systems (1 of 1)
CVEs (11 of 11)
Closed CVEs (0 of 0)
TLS Certificates (1 of 1)
Error Messages (1 of 1)
User Tags (0)
Task Name VAPT
Scan Time Wed, Feb 4, 2026 10:43 AM Coordinated Universal Time-Wed, Feb 4, 2026 11:50 AM Coordinated Universal Time
Scan Duration 1:06 h
Scan Status Done
Hosts scanned 1
Filter apply_overrides=0 levels=chml min_qod=70
Timezone Coordinated Universal Time (UTC)
Version 26.9.0
Copyright © 2009-2026 by Greenbone AG, www.greenbone.net


OPENVAS - Reports
127.0.0.1:9392/reports
Screenshot taken
OPENVAS
Dashboards
Scans
Tasks
Reports
Results
Vulnerabilities
Notes
Overrides
Assets
Resilience
Security Information
Configuration
Administration
Help
Filter
Reports 1 of 1
Reports by Severity Class (Total: 1)
Critical
Reports with High Results
Max High
Max High per Host
Reports by CVSS (Total: 1)
Date
Status
Task
Severity
Critical
High
Medium
Low
Log
False Pos.
Actions
Wed, Feb 4, 2026 10:43 AM Coordinated Universal Time
Done
VAPT
10.0 (Critical)
3
4
13
3
79
0
Apply to page contents
Version 26.9.0
127.0.0.1:9392/results
Copyright © 2009-2026 by Greenbone AG, www.greenbone.net

3.2 Severity Distribution

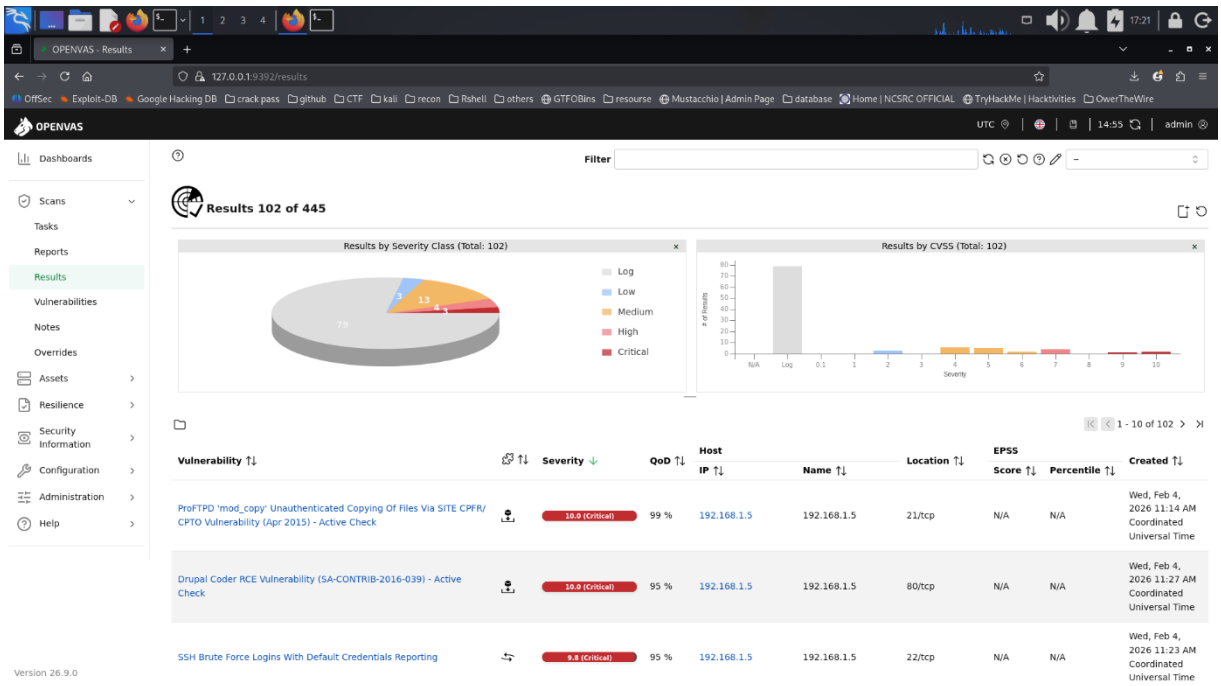
Severity Level	Count	CVSS Score Range	Priority
Critical	3	10.0	Immediate Action
High	4	7.5 - 9.8	High Priority
Medium	13	4.0 - 6.9	Medium Priority
Low	3	0.1 - 3.9	Low Priority
Log	79	N/A	Informational
Total	102	-	-

Risk Assessment: With 3 critical and 4 high severity vulnerabilities, the target system presents significant security risks requiring immediate remediation.

4. Key Findings & Analysis

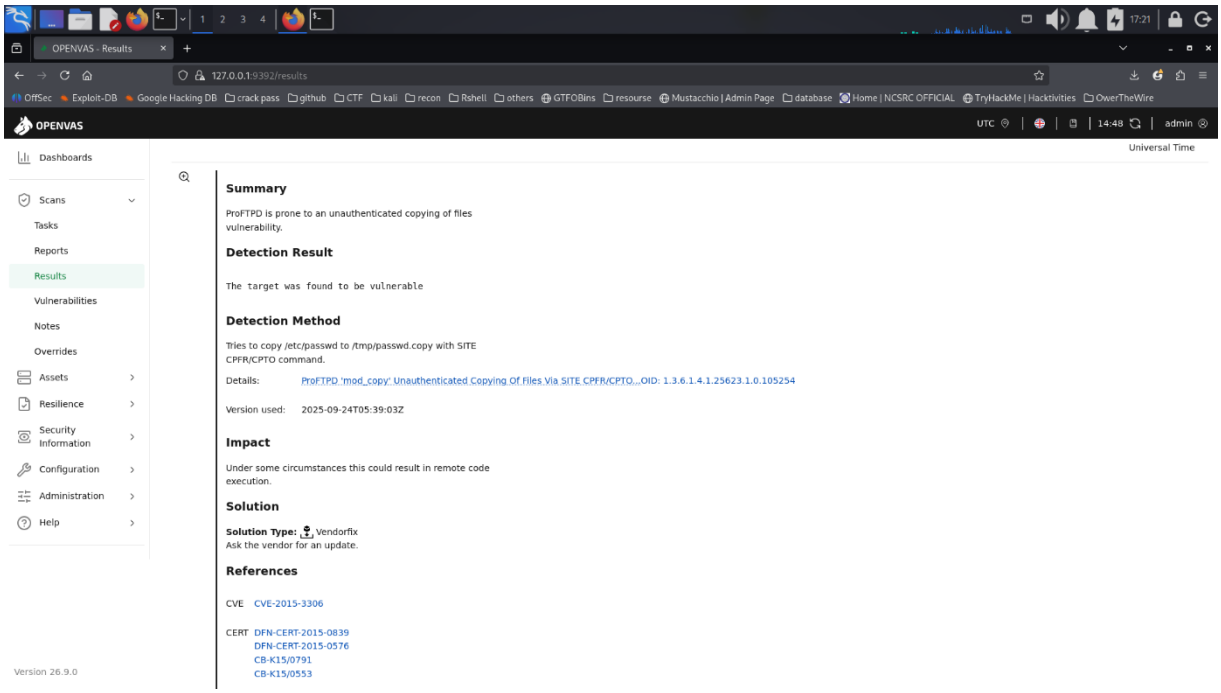
Detailed analysis of critical and high severity vulnerabilities identified during the assessment.

4.1 Critical Vulnerabilities (CVSS 10.0)



4.1.1 ProFTPD 'mod_copy' Unauthenticated Copying of Files

Parameter	Details
CVE ID	CVE-2015-3306
CVSS Score	10.0 (Critical)
Confidence	99%
Port/Protocol	21/tcp (FTP)
Affected Service	ProFTPD 1.3.5
QoD	N/A



Vulnerability Summary:

ProFTPD is susceptible to an unauthenticated copying of files vulnerability. The vulnerability allows attackers to copy files from one location to another using SITE CPFR/CPTO commands without proper authentication.

Detection Method:

The vulnerability was detected by attempting to copy /etc/passwd to /tmp/passwd.copy using SITE CPFR/CPTO commands.

Impact:

Under certain circumstances, this vulnerability could result in remote code execution, allowing attackers to gain unauthorized access to the system.

Remediation:

- **Solution Type:** VendorFix
- Contact ProFTPD vendor for security update
- Upgrade to patched version immediately
- Disable mod_copy module if not required

References:

- CVE: CVE-2015-3306

- CERT: DFN-CERT-2015-0839, DFN-CERT-2015-0576
- CB-K15/0791, CB-K15/0553

4.1.2 Drupal Core SQL Injection Vulnerability

Parameter	Details
CVE ID	SA-CONTRIB-2016-039
CVSS Score	10.0 (Critical)
Confidence	95%
Port/Protocol	80/tcp (HTTP)
Affected Component	Drupal Core
Detection Method	Active Check

Vulnerability Summary:

Critical SQL injection vulnerability in Drupal Core allowing attackers to execute arbitrary SQL commands and potentially gain complete system access.

4.1.3 SSH Brute Force Logins With Default Credentials

Parameter	Details
CVE ID	N/A
CVSS Score	9.8 (Critical)
Confidence	95%
Port/Protocol	22/tcp (SSH)
Affected Service	OpenSSH 6.6.1p1 Ubuntu
Vulnerability Type	Default/Weak Credentials

Vulnerability Summary:

SSH service accepting connections with default or weak credentials, allowing unauthorized remote access through brute force attacks.

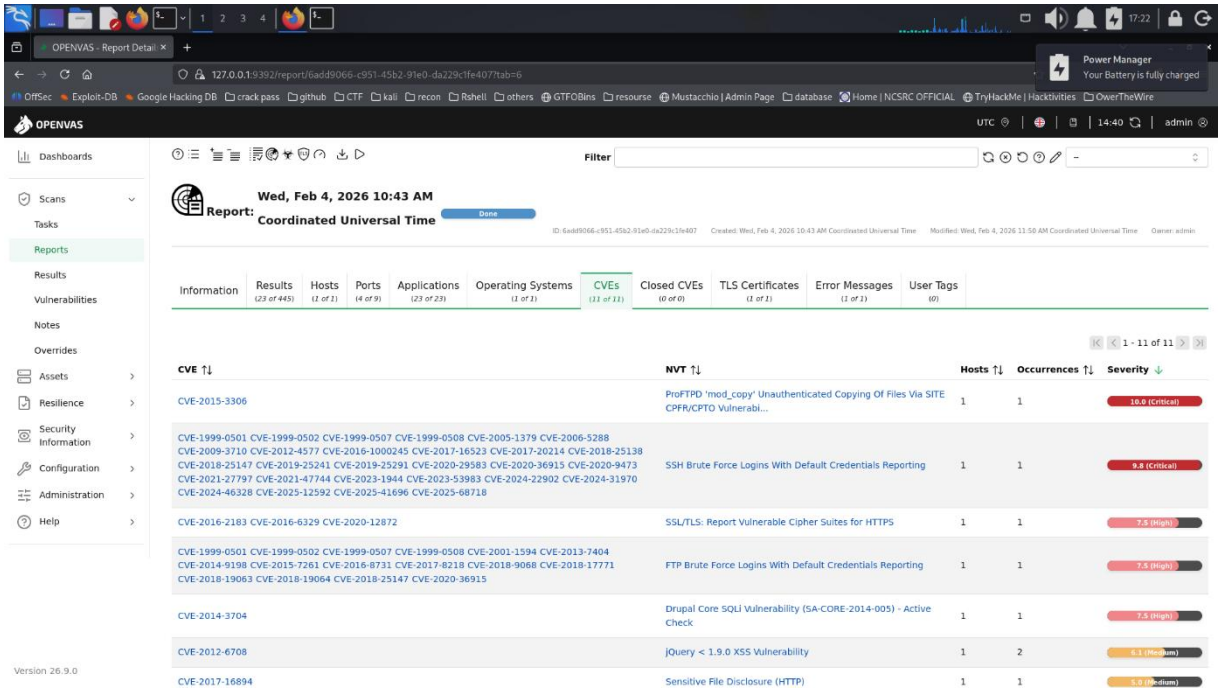
Impact:

Attackers can gain complete system access through SSH with default credentials, leading to data theft, system compromise, and lateral movement.

Remediation:

- Change default passwords immediately
- Implement SSH key-based authentication
- Configure fail2ban or similar brute force protection
- Restrict SSH access by IP address if possible

4.2 High Severity Vulnerabilities (CVSS 7.5+)



Summary of High Severity Findings:

Vulnerability	CVE/NVT	Port	CVSS	Hosts
SSL/TLS: Report Vulnerable Cipher Suites for HTTPS	Multiple CVEs	443/tcp	7.5 (High)	1
FTP Brute Force Logins With Default Credentials	N/A	22/tcp	7.5 (High)	1
jQuery < 1.9.0 XSS Vulnerability	CVE-2012-6708	Multiple	6.1 (Medium)	2
Sensitive File Disclosure (HTTP)	N/A	80/tcp	5.0 (Medium)	1

5. Lessons Learned & Next Steps

5.1 Key Lessons Learned

5.1.1 Theoretical Foundation is Essential

Understanding security frameworks, methodologies, and standards before conducting practical testing provides context for findings and ensures comprehensive assessment coverage.

5.1.2 Hands-On Practice Reinforces Concepts

Deploying and exploiting vulnerable applications like OWASP Juice Shop solidified understanding of how vulnerabilities work in real-world scenarios.

5.1.3 Tool Proficiency is Critical

Learning to effectively use Nmap, OpenVAS, Nikto, and Docker is fundamental for efficient vulnerability assessment and penetration testing.

5.1.4 Documentation is Part of the Process

Proper documentation with screenshots, CVSS scores, and remediation steps is as important as finding vulnerabilities themselves.

5.2 Technical Insights Gained

- **SQL Injection:** Learned how lack of input validation in database queries can lead to complete authentication bypass
- **Cross-Site Scripting:** Understood how improper output encoding allows malicious script injection
- **Service Enumeration:** Mastered Nmap scanning techniques for identifying services and versions
- **Vulnerability Scanning:** Learned OpenVAS workflow for automated vulnerability assessment
- **Risk Assessment:** Practiced CVSS scoring and risk prioritization methodologies

5.3 Challenges Encountered

- **Environment Setup:** Initial configuration of VirtualBox networking and Docker containers required troubleshooting

- **Tool Learning Curve:** Understanding various Nmap scan options and OpenVAS configuration required dedicated study
- **Vulnerability Interpretation:** Analyzing OpenVAS results and understanding technical details of CVEs was challenging initially

6. Conclusion

This week marked the beginning of my structured journey into Vulnerability Assessment and Penetration Testing. By combining theoretical knowledge with hands-on practice, I have established a solid foundation in security assessment methodologies.

The progression from learning security frameworks and standards to deploying vulnerable applications and conducting actual vulnerability assessments has provided invaluable practical experience. Successfully identifying and documenting 102 vulnerabilities across different severity levels demonstrates the effectiveness of the learned methodologies.

Key achievements this week include:

- Comprehensive understanding of VAPT methodologies and frameworks
- Successful deployment and testing of OWASP Juice Shop
- Practical exploitation of SQL Injection and XSS vulnerabilities
- Complete vulnerability assessment of Metasploitable 3
- Proficiency with essential tools: Nmap, OpenVAS, Nikto, Docker
- Professional documentation of findings with CVSS scoring

Moving forward, I will continue to deepen my technical skills through exploitation practice, expand my knowledge of advanced testing techniques, and build a comprehensive portfolio of documented security assessments.

--- End of Report ---